

Mini-Project 2: Network

The goal of this project is to learn how to perform an audit on a network with the intention to discover interesting characteristics and phenomena. The project is mostly open-ended (that is, there is no specific correct answer, and I do not have a working “solution.”). In doing so, you will be required to be creative and learn new tools. You will turn in a project report that describe both your findings and techniques used to discover these findings. Any custom scripts or tools built for the project should also be submitted with your report.

- The assignment will be submitted via GradeScope. If your GradeScope account was not automatically created and linked, click on the “Gradescope” assignment in Moodle and it should set you up.
- Contact the TA and Instructor if you are having trouble.

Points: Mini-Project 2 has a maximum of 100 points.

Collaboration:

- You may **not** collaborate on this mini-project. The project should be done individually.
- You **may** search the Internet for help, but you **may not** copy (either copy-and-paste or manual typing) code from another source without proper attribution.

Posting Solutions: You are explicitly forbidden from posting your solution in a public form (e.g., GitHub). If you need to share your solution as part of a job interview, you should create a private repository and grant that individual access. Please ask the instructor if you have any questions or concerns.

Dataset: For this assignment, we will use censys.io. You can create your own account. In addition we will send out invites for a team account. Please join the team account as soon as you receive the email invite as the link expires in 2 days. If you have not received this email or receive an error that the link has expired, please ask for a new invite. Once you have an account you will perform an audit on NC State’s networks using the IPv4 Hosts Search.

- **Important:** do not use tools that perform active scans on the NCSU networks, you must use censys.io, unless noted otherwise.

Censys.io API Query Limit: Both your censys.io account and the team account have an API query limit. When testing your code with a team account, please test using only a small number of queries to conserve the number of queries available for the rest of the class. We will monitor query usage and try to proactively increase the query limit before the team account runs out of queries. Please notify us if the team account has used up all queries.

Responsible Disclosure: As a result of this project, you may find a security issue within the NCSU network. We ask that you do not publicly disclose (e.g., Tweets, Snapchat, Blog Posts) any information about your findings for 90 days after the homework is due. This will allow us to report the findings to Security and Compliance and give them time to address the issue. However, you may discuss your findings with the instructor staff, or students in the class after the assignment is due.

Submission

What to submit: You should submit to GradeScope one `.pdf` and one `.tar.gz` or `.zip`.

- The first file should be a single PDF document with your report. Writeups submitted in Word or any non-PDF format will not be accepted. Consider using LaTeX to typeset your report. For a good primer on LaTeX, see the Not So Short Introduction to LATEX.
- The second file should be tarball (`.tar.gz`) or Zip (`.zip`) of any custom tools that are relevant to your report.

Part 1 (10 points): Network Address Identification

Before performing an audit you should always be sure the network addresses you plan to analyze belongs to the organization agreeing to be audited. The goal of this part is to familiarize the student with doing necessary reconnaissance and background research before performing an audit.

NC State owns multiple IPv4 network blocks.

- Identify at least 3 IPv4 blocks.
- For each block you identify, list the CIDR block, Network Name, Autonomous System Number (ASN), and Autonomous System Name.
- Additionally, describe your process for how you found this information, including screenshots as needed.

You must start your search using `censys.io`, from which you will identify at least the ASN. From there, you may use other resources to identify the CIDR blocks.

- **Reminder:** Do not use any tools that perform an active scan on the NCSU Network.

Part 2 (40 points): Network Summary

Once you have a list of target IP addresses identified in Part 1, the next step is to identify hosts on the network. The goal of this part is to familiarize yourself with gathering information about the network and organizing the information into a report that helps triage potential security issues.

Using `censys.io` perform an IPv4 Hosts Search on the network blocks identified in Part 1. Visualize the results of the search using tables or charts (e.g., bar graph). Include a discussion that interprets your visualizations, justifies why your visualizations are useful, and describes how you obtained the data.

Note: while it may be easier to get familiar with the search functionality using the web interface, I highly recommend using the API and writing scripts to save the results locally and then process the saved results with offline tools. This reduces the number of queries you will have to perform and reduces the chance that we will run out of queries. I recommend writing the scripts in Python, but you may use any programming language.

- **Reminder:** Do not use any tools that perform an active scan on the NCSU Network.

You must appropriately visualize and discuss the following information to receive 30/40 points:

1. hosts by operating system
2. hosts by web server (Apache, Nginx, IIS, etc.)
3. hosts by protocol

To receive the other 10 points you must be creative and go beyond the bare minimum described above.

To build your charts you may use any software you like, below are some suggested tools:

- Gnuplot is a command line graphing utility.
- Spreadsheets such as Microsoft Excel, LibreOffice Calc, or Google Sheets all have the capability to create charts.
- Plotly may be particularly useful for those using the Censys Python API to perform queries. After retrieving the data from Censys, you can easily output a Plotly chart from your script.

The following figure shows an example bar chart made with Plotly. You should use this as inspiration to create a chart using real data in your solution.

Count of Hosts by Operating System

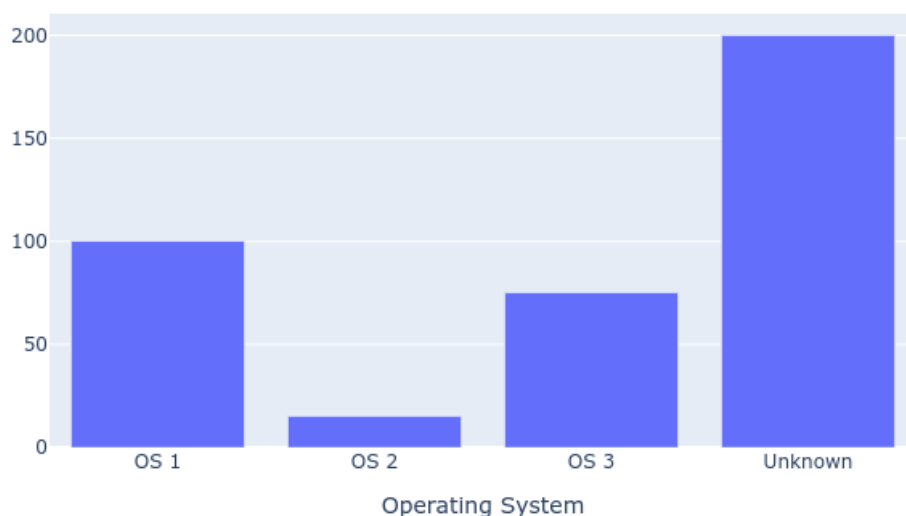


Figure 1: Sample figure showing bar chart for a limited number of Operating Systems.

Part 3 (20 points): Interesting Security Findings

The final step of an audit is to find and report security issues on the network. The goal of this part is to familiarize yourself with identifying security issues in a network.

Starting from the data you collected from censys.io, document an interesting security-related finding.

- Discuss why you found it interesting,
- background information about the finding,
- recommendations on how to address what you found,
- and a description on how you discovered the security issue.

Hint: you may create an account on shodan.io and use the Shodan API to identify security issues. The free version of Shodan limits the number of queries you can do per month, but we can use our censys.io information to more efficiently use Shodan.

For example, you may find a vulnerable host on the network. Give information about the vulnerable host, what the vulnerability is (cite a CVE if possible), and a description of how you found the vulnerable host on the network. Also list some recommendations to address the issue like updating the software or blocking certain ports.

A vulnerable host is not the only kind of security-related result, be creative.

- **Reminder:** Do not use any tools that perform an active scan or probe on the NCSU Network. If you find a host that you think is vulnerable, contact the teaching staff before attempting to connect to it.

If you are unable to find anything interesting, describe your thought process for partial credit. Please be as verbose as possible, describing what you tried and why you tried it. Also include any partial successes and possible reasons to why you think your approach was not successful.

Part 4 (20 points): Identifying External Shadow IT

When performing a security assessment of an organization, it is equally important to understand the exposure due to “Shadow IT”. The concept of shadow IT is fairly broad, as it encompasses anything that is not managed by the IT group at the organization. Over the past decade, the growing pervasiveness of cloud computing and cloud services has moved technology off-premises. For the purposes of this part, we will consider “shadow IT” as any host with an `ncsu.edu` hostname that does not have an IP address within the CIDR blocks assigned to NCSU’s ASN.

Thus, the goal of this part is to find IP addresses outside NCSU’s ASN that can be accessed via a `ncsu.edu` hostname. Note that if you did not identify a complete set of CIDR ranges in Part 1, your analysis might have some false positives. Therefore, it is a good idea to confirm the IP address is not in NCSU’s ASN using censys.io. You may also want to update your response to Part 1 after performing this investigation.

There are a number of ways you can discover these IP addresses without actively scanning the network. Here are two ideas (but you may use others):

- **DNS Data:** Censys.io can be queried via the API to retrieve forward DNS information, including A records and CNAME record responses. I expect that CNAME records are the most common way in which `ncsu.edu` domains are mapped to cloud services. However, it would also be interesting to find A records that point to non-NCSU IP addresses.
- **Certificate Data:** TLS certificates include the hostname in the “Common Name” field, as well as the `subjectAltName` field (aka “SAN” and “Subject Alternative Name”). censys.io and Google’s Certificate Transparency report both allows you to search TLS certificates by hostname. However, the trick will be mapping those hostnames to IP addresses.

Report your findings as well as how you found them. Include any scripts you used in your `.tar.gz/.zip` archive.

If you are unable to find anything, describe your thought process for partial credit. Please be as verbose as possible, describing what you tried and why you tried it.

Part 5 (10 points): Impact of IPv6

Censys and Shodan continuously scan the Internet to build their host databases. Discuss how IPv6, which use 128 bit addresses rather than 32 bit addresses, may impact the effectiveness of these tools. Scanning the IPv6 Internet: Towards a Comprehensive Hitlist may be a good place to begin your research. Remember to cite any sources you use.